

Data Governance

Where Does Your Data Live, and What Does That Mean?

PPOL 5206 | Massive Data Fundamentals | Spring 2026

Why Governance?

Section 1 · Opening

You Built a Pipeline. Now What?

S3 Bucket

Glue Crawler

Glue Catalog

Athena

Where does your data live: physically, legally, and temporally?

This is the governance problem.

Every technical decision you made in Weeks 6–7 has governance implications. Governance isn't added after the fact, it's embedded in architecture choices.

Governance Questions Hiding in a Data Pipeline

S3 Bucket

Who has access?
Is it encrypted?
What region?
Does that matter legally?
How long do files stay?

Glue Crawler

What if it crawled PII that
wasn't supposed to be
there?
What's the retention policy
for metadata?

Athena Queries

Who can run queries?
Are logs retained?
If a query returns SSNs,
where do those results land?

Every stage of the pipeline you built is also a governance decision point.

The Governance Framework

- | | | | |
|---|-----------------------|---|-----------|
| 1 | Legally | What rules govern this data? | Section 2 |
| 2 | Geographically | Where must it physically reside? | Section 3 |
| 3 | Temporally | How long must/should it exist? | Section 4 |
| 4 | Protectively | How do you ensure it survives? | Section 5 |
| 5 | Finally | How do you ensure it dies when it should? | Section 4 |

Every governance decision touches at least two dimensions. The hard problems touch all five.

The Rules

Section 2 · Privacy Law and Regulation

The U.S. Does Not Have a Single Privacy Law

Unlike the EU (GDPR), the United States has no comprehensive federal privacy statute.

Instead: sectoral regulations that govern specific types of data.

HIPAA

Health

PCI DSS

Finance

FERPA

Education

COPPA

Children

GLBA

Financial Institutions

CCPA

CA Consumers

Why sectoral? Health, finance, and education are the most personal aspects of people's lives. Government responded to that expectation domain by domain, not from a unified framework.

GDPR

General Data Protection Regulation (EU, 2018)

Rights-based approach: individuals own their data; organizations must justify processing it.

- Extraterritorial reach: applies to any entity processing EU residents' data
- Lawful basis for processing (consent is one of six)
- Data minimization: collect only what you need
- Purpose limitation
- Right to erasure ("right to be forgotten")
- Data protection by design and by default
- Breach notification: 72 hours
- Data Protection Officers (DPOs)

With GDPR, "what region is my S3 bucket in?" is a legal question, not just a technical one. More in Section 3.

HIPAA: Health Information

HIPAA-Protected

- Your doctor's records about you
- Hospital billing data
- Health insurance claims
- Pharmacy records

NOT HIPAA-Protected

- Your Fitbit/Apple Watch data
- Health apps on your phone
- Genetic testing (23andMe)
- Gym membership records

HIPAA doesn't protect "health data." It protects health data held by covered entities: healthcare providers, health plans, clearinghouses, and their business associates.

Safe Harbor: Remove 18 identifiers

Expert Determination: Statistical methods

The sectoral approach in action: regulation targets specific entities, not data types.

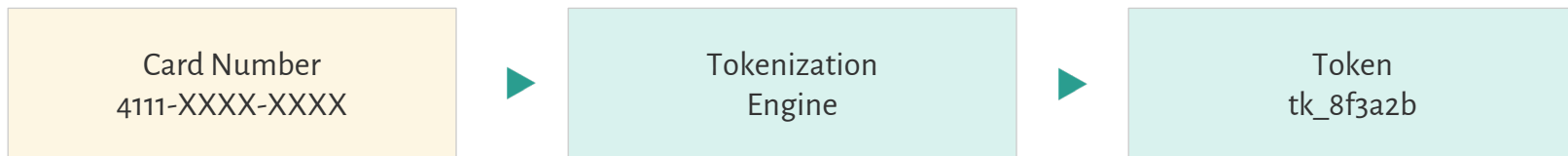
PCI DSS: Financial Data

Payment Card Industry Data Security Standard

**Not a law: industry
self-regulation**

- Enforced by card networks (Visa, Mastercard) through contracts, not government
- Applies to any entity that processes, stores, or transmits cardholder data
- 12 core requirements: network security, encryption, access control, monitoring, testing, policy

Tokenization: Minimizing Sensitive Data Exposure



Sometimes industry self-regulation is more demanding than government regulation. PCI DSS audits are rigorous.

FERPA: Education Records

Family Educational Rights and Privacy Act

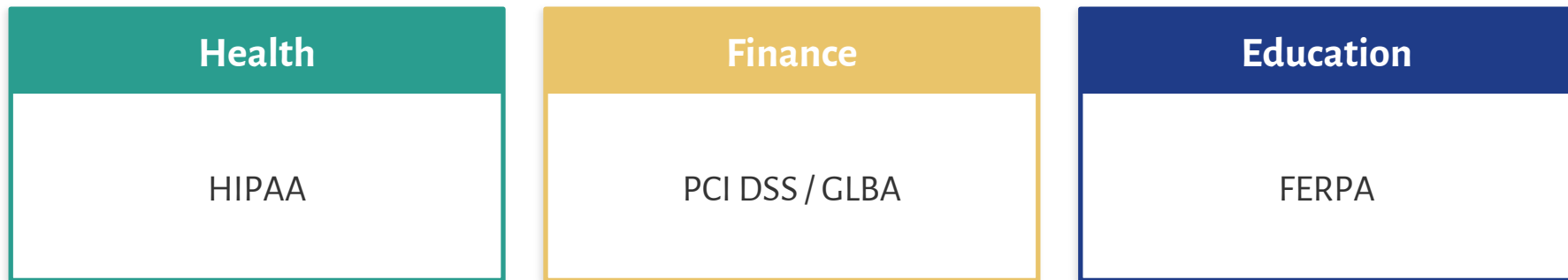
- Protects education records at institutions receiving federal funding
- Students (or parents if under 18) have rights to access and request correction
- Institutions cannot disclose without consent (exceptions: directory info, legitimate educational interest, health/safety)

What data does Georgetown hold about you right now? Who can see your grades? Your financial aid? Your disciplinary record?

Limits sharing of information, such as grades

You are living inside a governance framework right now.

The Pattern: Personal Domains, Sectoral Response



Personal vulnerability → Public demand → Sectoral regulation

Additional examples: COPPA (children), GLBA (financial institutions), SOX (corporate financial reporting), state breach notification laws

Understanding this pattern is predictive. What's the next domain? Social media? Genetic data? Location data? Why hasn't comprehensive regulation emerged there yet, or has it?

FISMA & FedRAMP: The Government Layer

FISMA

Federal Information Security
Modernization Act

Requires federal agencies to develop,
document, and implement information
security programs.

FedRAMP

Federal Risk and Authorization
Management Program

Cloud services must be FedRAMP-
authorized before agencies can use them.

FedRAMP Impact Levels

Low

Publicly available data

Moderate

Most federal systems

High

Law enforcement, emergency, financial,
health

FedRAMP is the gateway between commercial cloud and government use.

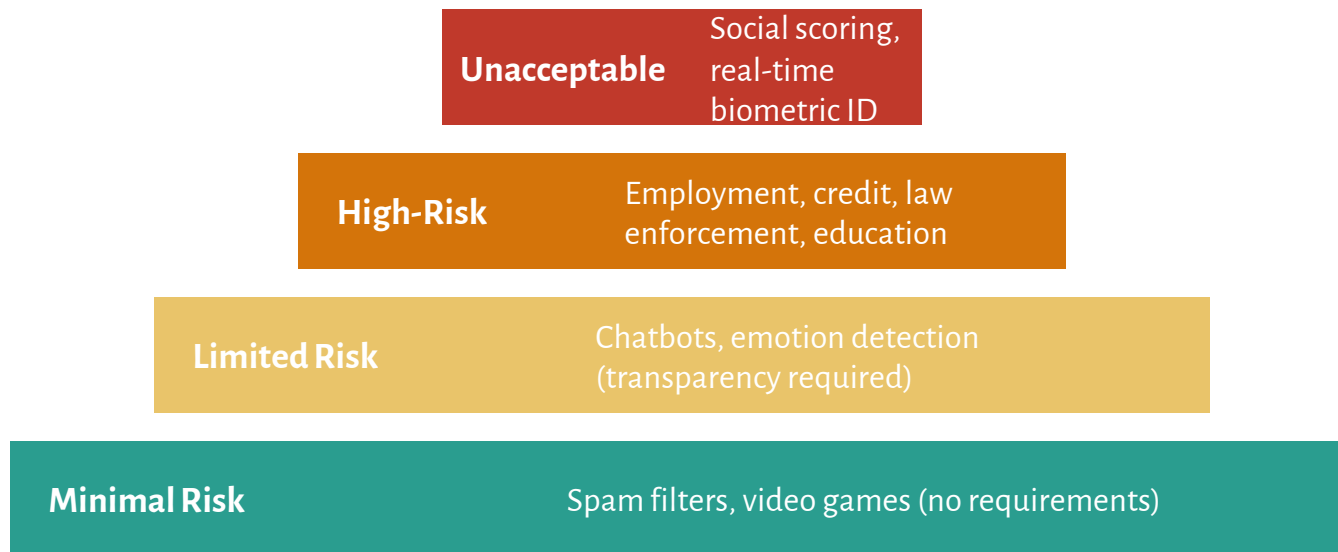
Discussion: When Regulations Collide

SCENARIO

A state health department wants to link Medicaid enrollment data (HIPAA) with school lunch program data (FERPA) to study childhood poverty. You are the data governance lead.

- 1 Which regulations apply? Where do they conflict?
- 2 What technical controls would you require? (De-identification, access restrictions, audit logging)
- 3 What would you want to be true about the governance framework, even if no law requires it?

AI Governance — The Rules Are Still Being Written



EU AI Act (2024)

U.S. Approach: Executive orders, voluntary commitments, sector-specific guidance, but no comprehensive federal AI legislation.

Data Sovereignty

Section 3 · Where Law Meets Geography

Which Law Applies? It Depends Where the Data Sits

Data Residency

Where data is stored at rest (a technical choice)

Data Localization

Laws requiring data to remain within borders (a legal constraint)

Transfer Restrictions

Rules governing cross-border data movement (a process constraint)

Operational Sovereignty

Who can access/operate systems — whose jurisdiction governs the people who touch it

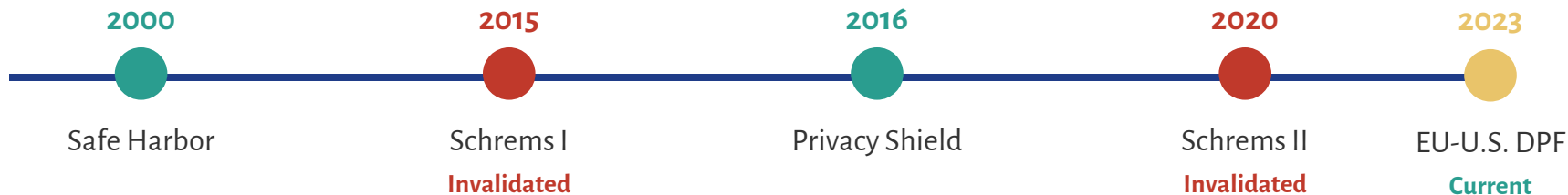
In Week 2, choosing an AWS region was a latency and cost decision. It's also a legal decision.

The Global Landscape of Data Localization

Jurisdiction	Key Requirements
EU (GDPR)	Transfers restricted to countries without “adequate” protection; requires SCCs or BCRs
China	Critical infrastructure data stored domestically; security assessments for cross-border transfers
Russia	Personal data of Russian citizens must be on servers physically located in Russia
India	Payment data must be stored in India; broader localization proposed
Brazil (LGPD)	Similar to GDPR; transfers require adequate protection in receiving country
U.S. (Federal)	FedRAMP for government; ITAR for defense; sector-specific; no single localization requirement

Localization requirements are expanding globally, not contracting. This shapes cloud architecture decisions.

Cross-Border Data Transfers: The Schrems Saga



How Organizations Move Data Legally

- **Adequacy decisions:**
 - EU Commission certifies countries providing “adequate” protection
- **Standard Contractual Clauses (SCCs):**
 - Pre-approved contract templates binding importers to EU protections
- **Binding Corporate Rules (BCRs):**
 - Internal rules for multinational intra-company transfers

One Austrian activist (Max Schrems) has twice overturned EU-U.S. data transfer mechanisms. Design systems to be adaptable.

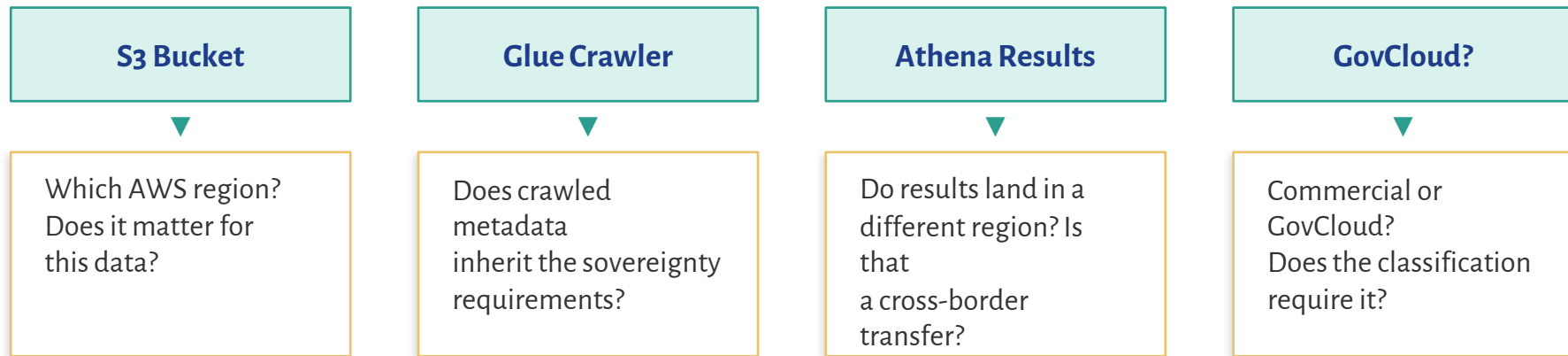
Sovereign and Private Clouds

Model	Examples	Why It Exists
Sovereign Cloud (EU)	AWS European Sovereign Cloud, Microsoft EU Data Boundary	GDPR + operational sovereignty
Government Cloud (U.S.)	AWS GovCloud, Azure Government	FedRAMP/FISMA + U.S.-person operations
DoD Cloud (U.S.)	AWS Secret/Top Secret regions	IL4/IL5/IL6 classification
Domestic-Only (China)	AWS China (Sinnet), Azure China (21Vianet)	Chinese law: domestic entities only

Key distinction: Data residency $\neq$ Operational sovereignty. Even if data is in an EU region, support personnel from outside the EU could access it. Sovereign clouds address both.

Week 7: Lake Formation enforces access within a cloud. Sovereign clouds enforce jurisdiction over the cloud itself.

Sovereignty Meets Your Pipeline



Every region selector dropdown you click in the AWS console is a sovereignty decision.

Data Sovereignty: What to Remember

- Data is subject to the laws where it resides and often where the data subjects reside too
- Localization laws are expanding globally, not contracting
- Cross-border transfer mechanisms are legally fragile (Schrems saga)
- Sovereign cloud offerings address both residency and operational control
- For your career: sovereignty shapes architecture decisions from day one

Now we know what the rules are and where they apply. Next question: how long should data exist?

How Long Does The Data Live?

Section 4 · Data Retention, Deletion & the Lifecycle

The Retention Dilemma

Keep Everything

- Future value is unpredictable
- Analytics improve with more history
- Legal discovery may require it
- Storage is cheap

Delete Aggressively

- Every record can be breached
- Regulations may require deletion
- Old data increases exposure
- Data you don't have can't leak

Three Drivers of Retention

Legal/Regulatory

Minimum periods (tax: 7yr, HIPAA: 6yr)

Litigation Holds

Suspend deletion when litigation anticipated

Operational Value

How long is it useful? (Inherently uncertain)

Retention is a decision under uncertainty.

Retention Schedules in Practice

Data Category	Retention Period	Legal Basis
Employee tax records	7 years	IRS
Patient medical records	6 yrs (varies by state)	HIPAA
Student education records	5 yrs after attendance	FERPA
Federal agency records	Per NARA schedule	Federal Records Act
Cardholder data	Relationship + 1yr logs	PCI DSS
Web analytics	13–26 months	GDPR minimization

The GDPR tension: the right to erasure can override your retention schedule unless a legal basis takes precedence (e.g., tax compliance). Navigating that conflict is a governance problem.

A retention policy is a decision framework, not a single number.

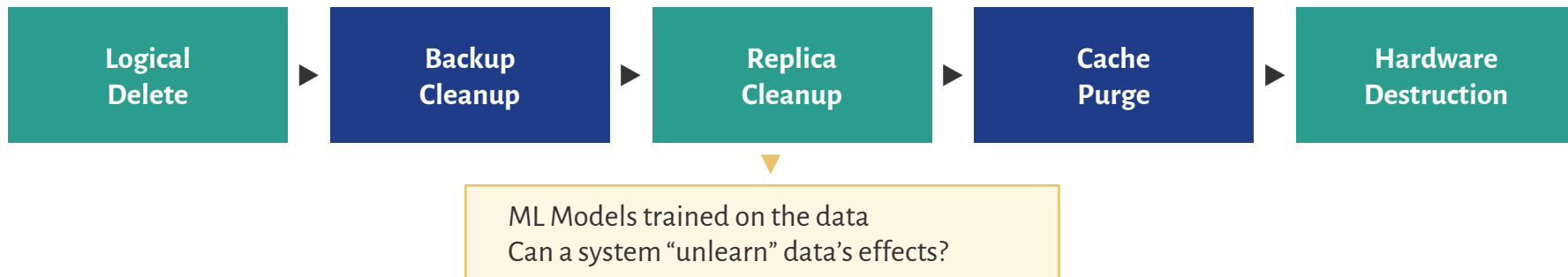
Storage Tiers as a Retention Strategy

S3 Standard	Frequent access	\$\$\$
S3 Infrequent Access	Monthly or less	\$\$
Glacier Instant	Rare, fast access	\$
Glacier Flexible	Rare, hours OK	¢
Glacier Deep Archive	Almost never, 12+ hrs	¢¢

S3 Lifecycle Policies automate transitions between tiers (governance as code).

You don't always have to choose between keeping and deleting. Data "cools down" over time.

Deletion: Harder Than You Think



- **The “proving deletion” problem:**
- Under GDPR, you may need to demonstrate data was deleted. Proving something doesn’t exist across backups, replicas, and analytics copies is genuinely difficult.
- **Hardware disposal:**
- AWS degausses and physically destroys drives per NIST 800-88. When your agency replaces laptops, what happens to the drives?

The VA lost a laptop in 2006 with unencrypted records of 26.5 million veterans. Physical security is governance.

Immutable Storage and Audit Integrity

S3 Object Lock (WORM)

Write Once, Read Many. Cannot be deleted until retention expires. Governance mode vs. Compliance mode.

Immutable Audit Logs

CloudTrail logs should be immutable. If breached, attackers can't delete evidence.

Ledger Databases

Append-only records. Useful for financial transactions, regulatory submissions, chain-of-custody.

Ransomware Defense

Immutable backups are the primary defense. If the backup is immutable, attackers can't encrypt it.

Immutability = Proof of Integrity

Retention and Deletion: What to Remember

- Retention is a decision under uncertainty with competing pressures
- Storage tiers reduce cost without requiring deletion (data “cools down”)
- Deletion is harder than it looks (backups, replicas, ML models)
- Hardware disposal matters (physical security is governance)
- Immutability serves three purposes: compliance, evidence, and ransomware defense
- Lifecycle policies and Object Lock are governance as code

We've covered where data lives legally, geographically, and temporally. Now: what happens when systems fail?

When Things Go Wrong

Section 5 · Disaster Recovery & Business Continuity

Backup ≠ Disaster Recovery

BACKUP

A copy of data, stored separately.

Answers: “Can I get my data back?”

DISASTER RECOVERY

The full plan to restore operations.

Answers: “Can I get systems running, and how fast?”

A backup without a recovery plan is a file sitting in a bucket.

A recovery plan without tested backups is a wish.

Snapshots vs. Backups

Backup: Independent copy for recovery

Snapshot: Point-in-time system image
(incremental, dependent on source)

Snapshot Uses Beyond Recovery

Replicability

Spin up an identical environment from a snapshot

Experimentation

Snapshot before a risky change; roll back if it fails

Data Sharing

Share a snapshot for analysis without production access

Compliance Testing

Test controls against a snapshot, not production

Snapshots containing PII are themselves governed data. A snapshot shared for “experimentation” with real customer records is a potential compliance violation.

RPO & RTO: The Two Key Metrics

RPO: Recovery Point Objective

How much data loss is acceptable?

911 system: near zero

Quarterly reports: hours may be fine

RTO: Recovery Time Objective

How long can systems be down?

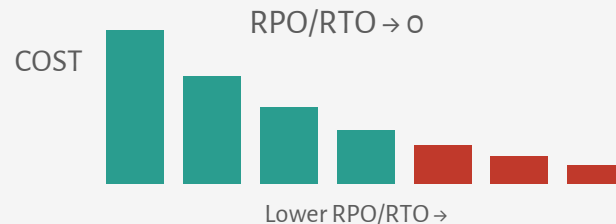
E-commerce on Black Friday: near zero

Internal dashboard: a day may be fine

The Cost Curve

As RPO and RTO approach zero, cost increases exponentially.

This is a resource allocation problem.



What's the RPO for the Census Bureau's decennial data? What about a hospital's patient records?

Hot, Warm, and Cold Sites

	Status	Activation	Cost	S3 Analogy
Hot Site	Fully operational, synced	Minutes	Very High	S3 Standard
Warm Site	Hardware in place, data needs loading	Hours—day	Moderate	S3 IA
Cold Site	Empty facility, everything TBD	Days—weeks	Low	Glacier

The 9/11 Lesson

Many financial firms in Lower Manhattan had hot backup sites in New Jersey. The data was fine. The infrastructure was ready. But the people who knew how to operate those systems were trapped south of 14th Street, transit was shut down, and communications were overwhelmed.

Backup sites without a plan for getting trained staff there are incomplete. DR planning is organizational, not just technical.

Federal context: Continuity of Operations (COOP) planning, every agency is required to have one.

Backup Strategies: 3-2-1 and GFS

3

copies of
your data

2

different storage
methods

1

copy offsite
(different region)

Grandfather-Father-Son Rotation

Son

Daily
1 week

Father

Weekly
1 month

Grandfather

Monthly
1 year+

- Cloud implementation: S3 versioning, cross-region replication, automated RDS/Aurora backups
- Immutable backups protect against ransomware (callback to Slide 28)

When you turned on S3 versioning in Week 6, you were implementing part of this strategy.

Disaster Recovery in the Cloud

- **S3 versioning:**
 - Every object version retained, accidental overwrites are recoverable
- **Cross-region replication:**
 - If us-east-1 goes down, your data exists in us-west-2
- **Automated backups for RDS/Aurora**
 - Configurable retention, point-in-time restore
- **Backup as a Service (BaaS):**
 - Managed scheduling, retention, monitoring
- **DRaaS:**
 - Full managed recovery, infrastructure, data, and applications

Cloud providers have commoditized many DR capabilities ... but you still need to configure and test them.

Breach Response: When Governance Fails



Incident Response Cycle



- Your role as data scientist: you understand the data. You assess what was exposed, the scope, and who's affected.
- Retention connection: if you retained data longer than necessary and it gets breached, you've increased the scope of impact.

The time to write your incident response plan is not during the incident.

Scenario: Friday Afternoon Disaster

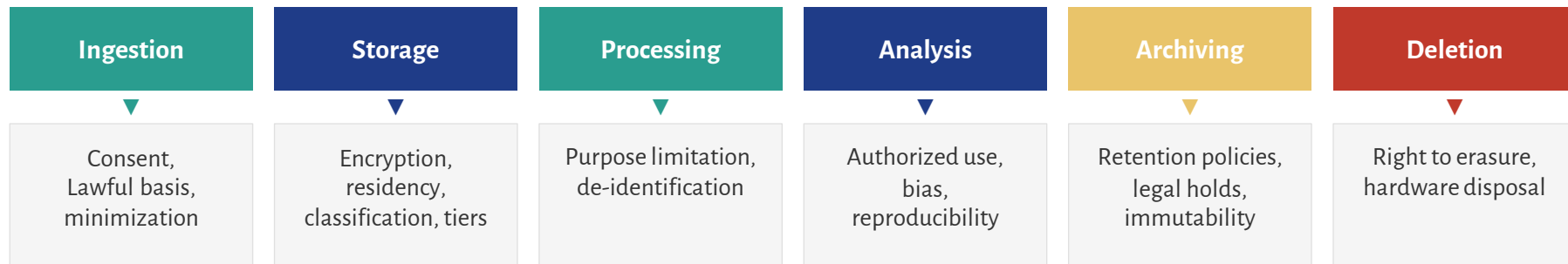
4:30 PM FRIDAY: Your team's primary RDS database is corrupted. It feeds a public-facing dashboard tracking federal grant disbursements.

- 1 Your DR failover is in us-west-2, but 30% of records belong to EU citizens in an international grant program. Does failover create a GDPR transfer issue?
- 2 The backup you'd restore is 6 months old. Does it contain records that should have been deleted under your retention schedule?
- 3 Your hot site is ready, but your DBA is on vacation. Who can operate the recovery?
- 4 What's your communication plan? Who gets notified, in what order?

Putting It All Together

Section 6 · Synthesis & Closing

Governance Across the Data Lifecycle



Each stage is both a technical operation and a governance decision.

The governance overlay changes what questions you ask at every step
From “how do I store this?” to “am I allowed to store this, and for how long?”

Your Competitive Advantage

You might be the person who...	Which means you need to understand...
Writes the privacy policy	The technical controls that make it enforceable
Builds the pipeline	The legal, sovereignty, and retention constraints on design
Audits compliance	The rules, systems, retention schedules, and audit trails
Responds to a breach	The data, the law, notification timelines, and the DR plan
Negotiates a cloud contract	Sovereignty requirements, SLAs, and residency guarantees

The people who can operate in both columns are rare and extraordinarily valuable.

Week 8 — Key Concepts

Regulations

GDPR, FERPA, HIPAA, PCI DSS, CCPA/CPRA, FISMA, FedRAMP, COPPA, GLBA, EU AI Act

Sovereignty

Data residency, localization, operational sovereignty; SCCs, BCRs, Schrems; EU-U.S. DPF

Private Clouds

GovCloud, IL4/IL5, EU Sovereign Cloud, China domestic clouds

Retention

Retention schedules, litigation holds, S3 Lifecycle Policies, storage tiers, Object Lock, WORM

Deletion

Logical deletion, proving deletion, hardware disposal (NIST 800-88), ML unlearning

DR/BC

RPO, RTO, hot/warm/cold sites, COOP, 3-2-1, GFS, snapshots vs. backups, breach response

Further Reading

- **GDPR: Articles 5–7, 17, and 44–49**
- Principles, consent, right to erasure, and cross-border transfer rules
- **PCI DSS Quick Reference Guide**
- Concise overview of the 12 requirements
- **AWS Well-Architected Framework, Security Pillar**
- How a cloud provider thinks about governance
- **NIST Privacy Framework**
- The U.S. government's approach to privacy risk management
- **EU-U.S. Data Privacy Framework overview**
- The current cross-border mechanism — see the fragility of these agreements
- **OPM Data Breach Case Study (2015)**
- 21.5 million federal personnel records — governance failures at multiple levels